

Desafio Prático: Auditoria de IAM

Simulação avançada de governança e conformidade em instituição financeira: 500 usuários, 80 contas privilegiadas e ecossistema híbrido.



Simulação do Cenário Corporativo

Escopo e ecossistema tecnológico auditado na instituição financeira

Leitura do cenário

O cenário combina identidades, privilégios e recursos em ambientes híbridos. A análise considera tanto o acesso dos usuários quanto a exposição dos recursos críticos.



Métricas da Simulação

500 usuários totais e **80 contas privilegiadas** operando em infraestrutura crítica com exposição a risco financeiro direto.



Ambientes Envolvidos

Azure AD, hoje Microsoft Entra ID (SSO via SAML e OIDC), 12 aplicações SaaS corporativas, servidores Windows/Linux on-premises e cofre CyberArk parcial.

Achados Preliminares da Auditoria

Vulnerabilidades críticas identificadas na coleta inicial de evidências

Interpretação dos achados
Os achados concentram-se em autenticação, gerenciamento de sessão, contas críticas e monitoramento. Em conjunto, essas condições ampliam a superfície de ataque e dificultam a rastreabilidade.

- 

MFA Parcial: apenas 60% dos usuários ativos com MFA; administradores usando exclusivamente SMS, vulnerável a SIM swap e interceptação.
- 

Sessões e Tokens: sessões SAML de 8 horas sem reautenticação; apps OIDC sem refresh token rotativo; sessões RDP privilegiadas sem gravação.
- 

Contas Críticas e Logs: contas de serviço com privilégio permanente e sem rotação de senha; logs do Azure AD sem monitoramento nem alertas.

Entregável 01: Seleção e Fundamentação da Norma

Justificativa técnica rigorosa alinhada ao perfil de instituição financeira regulada

Relação entre as referências

As referências sustentam frentes complementares: proteção da identidade, controle do acesso e proteção das transações e dos dados. Versões vigentes: ISO/IEC 27001:2022, com o Anexo A renumerado, e PCI DSS v4.0.1, que substituiu a v4.0 em 31/12/2024.

ISO/IEC 27001:2022 Por que escolher: padrão global de SGSI, base de governança e certificação no setor financeiro. Controles-chave (2013 → 2022): A.9.4.2 → A.8.5: procedimentos seguros de log-on (autenticação segura). A.9.2.3 → A.8.2: gestão de direitos de acesso privilegiado. A.12.4 → A.8.15 e A.8.16: registro e monitoramento de eventos.	NIST SP 800–53 Rev. 5 Por que escolher: granularidade técnica de controles e melhorias (enhancements) para especificar cada correção. Família IA (Identification and Authentication): IA-2(1) e IA-2(2) MFA, IA-5 gestão de autenticadores, IA-11 reautenticação. Família AC (Access Control): AC-2 contas, AC-6 menor privilégio, AC-12 encerramento de sessão, AC-17 acesso remoto.	PCI DSS 4.0.1 Por que escolher: obrigatório para quem processa, armazena ou transmite dados de cartão. Req. 8.2: ciclo de vida das contas, incluindo 8.2.5 (revogação de desligados) e 8.2.8 (sessão inativa). Req. 8.3: autenticação forte e senhas. O MFA está nos 8.4 e 8.5, e as contas de serviço no 8.6. MFA resistente a phishing é recomendado, mas não exigido pelo padrão.
--	---	--

Entregável 02: Mapeamento Avançado de Gaps Normativos

Vinculação direta entre achados da simulação, controles violados e impactos (C.I.D.)

Leitura dos gaps
Cada achado é vinculado ao controle violado nas três normas, ao risco (alto, médio ou baixo) e ao impacto em Confidencialidade, Integridade e Disponibilidade. A ISO é citada na numeração 2013, com o equivalente 2022 entre parênteses.

- MFA limitado (60% usuários / SMS admins):** viola ISO 27001 A.9.4.2 (A.8.5) e A.9.2.3 (A.8.2), NIST IA-2(1), IA-2(2) e IA-5, e PCI DSS 8.3.1 e 8.4.1 a 8.4.3. **Risco: Alto. Impacto:** C alto · I alto · D médio.
- Sessões SAML de 8 h e apps OIDC sem refresh token rotativo:** viola ISO 27001 A.9.4.2 (A.8.5), NIST AC-12 e IA-11, e PCI DSS 8.2.8. **Risco: Alto. Impacto:** C alto · I médio · D baixo.
- RDP privilegiado sem gravação:** viola ISO 27001 A.12.4.3 (A.8.15) e A.9.2.3 (A.8.2), NIST AC-17(1) e AC-6(9), e PCI DSS 8.2.1 e 10.2.1.2. **Risco: Alto. Impacto:** C médio · I alto · D baixo.
- Contas de serviço permanentes e sem rotação:** viola ISO 27001 A.9.2.3 (A.8.2), NIST AC-6(5) e IA-5, e PCI DSS 8.6.1 a 8.6.3. **Risco: Alto. Impacto:** C alto · I alto · D alto.
- Logs do Azure AD não monitorados:** viola ISO 27001 A.12.4 (A.8.15 e A.8.16), NIST AC-2(4) e AC-2(12), e PCI DSS 10.4.1, já que o Req. 8 não cobre monitoramento. **Risco: Alto. Impacto:** C alto · I alto · D médio.

Entregável 03: Plano de Remediação Robusto

Mitigações estruturadas para o ecossistema híbrido (Azure AD + On-Premises)

Evidência de remediação

A evolução do tratamento pode ser demonstrada por configurações aplicadas, registros de autenticação, trilhas de auditoria e evidências de monitoramento.

Fase 1: Identidade, MFA & Logs ATÉ 30 DIAS - Implantação de Conditional Access exigindo MFA para 100% dos 500 usuários, exceto 2 contas de emergência monitoradas; bloqueio de autenticação legada. - Eliminação total de SMS para admins, com força "MFA resistente a phishing" e chaves físicas FIDO2. - Logs do Azure AD no Microsoft Sentinel com alertas de conta de emergência, password spray, fadiga de MFA e função atribuída fora do PIM.	Fase 2: Cofre & Privilégios ATÉ 60 DIAS - Rollout completo do CyberArk, hoje parcial, para as 80 contas privilegiadas e as contas de serviço. PSM como caminho único de RDP, com gravação integral das sessões. - Arquitetura <i>Just-In-Time (JIT)</i> e <i>Just-Enough-Administration (JEA)</i>; nenhuma conta de serviço no Domain Admins. - Rotação pelo CPM: senha de uso único para pessoas; contas de serviço em intervalo definido por risco, lendo a senha do cofre.	Fase 3: Sessões & Governança ATÉ 90 DIAS - Apps SaaS críticos com frequência de entrada de 1 h, timeout de 15 min e Single Logout. - Desligamento com desprovisionamento automático via SCIM e revogação imediata de sessões. - Refresh token rotativo nos apps OIDC; o SAML não usa refresh token. - Auditorias trimestrais automatizadas de privilégios (revisões de acesso no PIM).
--	--	--

Relatório de Auditoria: Cenário 01

Simulação de incidente com credencial vazada e ausência de MFA resistente a phishing

Ponto de atenção
O cenário evidencia a importância de autenticação resistente a phishing para acessos administrativos e de análise de eventos fora do padrão.

Achado	Acesso VPN não autorizado, em horário incomum, com conta administrativa cujo MFA por SMS foi interceptado via SIM swapping.
Norma violada	ISO 27001 A.9.4.2 (A.8.5) · NIST IA-2(1) e AC-2(12) · PCI DSS 8.4.1 e 8.4.3 (MFA em acesso administrativo e remoto).
Evidência	Logs da VPN e de entrada do Azure AD (IP de origem, horário e método “SMS”) e registro de troca de chip junto à operadora.
Risco	Alto · C alto · I alto · D médio.
Recomendação	Contenção: revogar sessões, trocar credenciais e investigar o que foi feito na sessão. Exigir FIDO2 para administradores e autenticar a VPN via SAML/OIDC no Azure AD, já que RADIUS não suporta FIDO2. Criar alerta para acesso fora do padrão.
Prazo	Contenção em 24 horas; FIDO2 para administradores em 15 dias; VPN integrada ao Azure AD em 30 dias.
Referências	NIST SP 800-63B-4 (SMS como autenticador restrito) · W3C WebAuthn / FIDO2 · RFC 2865 (RADIUS).

Relatório de Auditoria: Cenário 02

Simulação de movimentação lateral e persistência via conta de serviço estática

Ponto de atenção
Contas de serviço exigem controle de ciclo de vida, revisão periódica de privilégios e registro das atividades realizadas em seu nome.

Achado	Conta de serviço com privilégio Domain Admin, senha sem rotação há 2 anos e gravada em script legado sem monitoramento.
Norma violada	ISO 27001 A.9.2.3 (A.8.2) · NIST AC-6(5) e IA-5(7) · PCI DSS 8.6.2 e 8.6.3 (contas de sistema e aplicação).
Evidência	Membros do grupo Domain Admins, data da última troca de senha (pwdLastSet) e trecho do script com a senha em texto claro.
Risco	Alto · C alto · I alto · D alto, pois o comprometimento atinge todo o domínio.
Recomendação	Retirar a conta do Domain Admins e conceder só os direitos necessários. Fazer o script obter a senha do CyberArk (Credential Provider) e só então ativar a rotação automática pelo CPM. Negar logon interativo e monitorar o uso da conta.
Prazo	Retirada do Domain Admin e troca da senha, com ajuste do script, em 7 dias; integração ao CyberArk com rotação automática em 30 dias.
Referências	RFC 4120 (Kerberos): senhas estáticas expõem a conta a Kerberoasting · MITRE ATT&CK T1558.003 e T1552.001.

Relatório de Auditoria: Cenário 03

Simulação de sessão SAML ativa após desligamento em aplicações SaaS

Ponto de atenção
A proteção de tokens depende de controle de acesso, armazenamento adequado, expiração e monitoramento de comportamentos anômalos.

Achado	Colaborador desligado continuou acessando dados financeiros em aplicação SaaS porque a sessão SAML de 8 horas seguiu válida após o bloqueio da conta.
Norma violada	ISO 27001 A.9.2.6 (A.5.18) e A.9.4.2 (A.8.5) · NIST AC-2 e AC-12 · PCI DSS 8.2.5 (revogação imediata de desligados) e 8.2.8.
Evidência	Horário do bloqueio no Azure AD comparado aos logs de acesso do SaaS após o desligamento; asserção SAML com SessionNotOnOrAfter de 8 horas.
Risco	Alto · C alto · I médio · D baixo.
Recomendação	Desprovisionamento automático via SCIM e revogação de sessões no desligamento; frequência de entrada de 1 h para apps críticos; timeout de sessão e Single Logout no SaaS. O SAML não usa refresh token: a rotação vale para os apps OIDC.
Prazo	Revogação de sessões no processo de desligamento em 10 dias; SCIM e ajustes nos SaaS em até 90 dias.
Referências	OASIS SAML 2.0 (SessionNotOnOrAfter, Single Logout) · RFC 7644 (SCIM) · RFC 9700 (OAuth 2.0 Security BCP).

Critérios de Validação e Avaliação

Parâmetros acadêmicos e técnicos para aprovação do projeto de auditoria IAM

Rigor Técnico & Normativo

- Precisão na correlação entre achados e controles (ISO 27001, NIST, PCI DSS).
- Viabilidade técnica das mitigações propostas para o ecossistema híbrido.

Clareza & Estruturação

- Coerência na formatação dos relatórios de auditoria (Achado → Norma → Evidência → Risco → Recomendação → Prazo).
- Linguagem executiva e alinhada com governança de TI.

Aplicabilidade Prática

- Efetividade das políticas de Conditional Access, FIDO2, CyberArk e Sentinel.
- Mitigação real de riscos para os 500 usuários e 80 contas privilegiadas.

Leitura final

A avaliação pode ser sustentada pela combinação entre evidência técnica, clareza da análise e aplicabilidade prática das medidas propostas.

Conclusão do Desafio IAM

A simulação de auditoria consolidou a aplicação prática de normativas internacionais (ISO/IEC 27001:2022, NIST SP 800-53 Rev. 5, PCI DSS 4.0.1) na proteção de identidades e acessos em ambientes financeiros híbridos.

APLICAÇÃO PRÁTICA

A simulação conecta os conceitos de IAM aos cenários de autenticação, privilégios e monitoramento apresentados ao longo do desafio.

CONTROLE CONTÍNUO

A proteção de identidades depende de acompanhamento permanente, revisão de acessos e observação dos eventos relevantes.

RESULTADO ESPERADO

Com os controles aplicados e as evidências registradas, a organização consegue demonstrar redução da exposição e maior rastreabilidade.